

TRIAGUE TÉCNICO

Hecho por

Johan Sebastián Castro Gonzalez

Juan Pablo Mozuca Chaparro

David Santiago Beltran Pedraza

Servicio Nacional de Aprendizaje (SENA)

ADSO - 3203084

Junio de 2026

Hallazgos Arquitectónicos y de Seguridad

Al momento de trabajar en esta refactorización que hicimos del sistema pues básicamente los 5 hallazgos más graves que encontramos o que podemos ver en el código fueron los siguientes:

- **1. El código espagueti:** Encontramos que en este código el archivo que manejaba el sistema bancario pues básicamente tenía una estructura desordenada y con todas las funciones o estructuras del sistema en el mismo archivo lo cual pues lo hace difícil de entender o puede generar confusiones con todo ese código aglomerado.
 - **Impacto en producción:** Pues básicamente si esto se sube a producción si se llegará a necesitar hacer un arreglo o modificación en el código pues este al estar todo en un mismo archivo pues va a ser muy complejo e incómodo el tema de arreglar alguna función o estructura ya que al no estar cada sección separada según la función en general pues esto puede ocasionar errores en pruebas, destrucción de código por error que se enlaza con otras funciones o que el mismo desarrollador tenga que estar mucho tiempo buscando la estructura a modificar sin que afecte otro bloque.
- **2. El problema de concurrencia:** En el código pues básicamente podemos ver que al ejecutar el servidor web pues este ejecutaba hilos seguidos al responder solicitudes HTTP donde abre, lee y reescribe el archivo de las cuentas del banco.
 - **Impacto en producción:** Pues lo que esto ocasiona es que si dos usuarios generan una petición HTTP al tiempo pues afectaba a ambas cuentas bancarias donde el sistema pues toma el mismo saldo con el que inician y el último hilo que se termina de ejecutar sobrescribe ese saldo de los dos obviamente afectando la transacción de las personas de manera muy grave.
- **3. Transferencias por montos negativos:** En el código no se define cómo va a funcionar el tema de los montos o los valores numéricos a la hora de hacer una transferencia.

- **Impacto en producción:** Básicamente al no definir cómo va a funcionar esa lógica numérica del banco como evitar que haya límites de dinero negativos o que el usuario ingrese montos negativos, pues justamente esto es un error de vulnerabilidad del sistema en el cual puede generar o que las personas intenten sacar más o transferir plata de forma infinita aprovechándose de la ley de signos que aplicaría el sistema o que generará errores por intentar sacar un monto negativo.
- **4. La validación de transferencias a cuentas desactivadas:** En la lógica del código el sistema aunque verifica los IDs en la base de datos no tiene en cuenta el estado lógico o el administrativo de las cuentas, es decir solo revisa que el número de cuenta exista más no su estado.
 - **Impacto en producción:** Básicamente en lo que esto afecta es en que el usuario llegue a hacer transferencias a cuentas que no están activas por alguna u otra razón e incluso que cuentas que por ejemplo están bloqueadas o congeladas puedan seguir actuando con normalidad en el sistema lo cual obviamente sería un problema gravísimo tanto para el usuario como para la empresa y que implicaría consecuencias legales fuertes.
- **5. Los EndPoints de los administradores son visibles:** La ruta que configura y cambia el estado de los clientes como activos o bloqueados (bypass-status) se ejecuta de forma pública en la red y no pide ninguna autenticación.
 - **Impacto en producción:** Básicamente alguien que tenga acceso a un cliente HTTP como Postman con el enlace de alguna petición puede modificar cuentas bancarias que se encuentren en el sistema y bloquearla o desbloquearla cosa que solo deberían poder hacer los admins.